

Remediation Criticità della macchina virtuale Metasploitable 2

28/06/2026

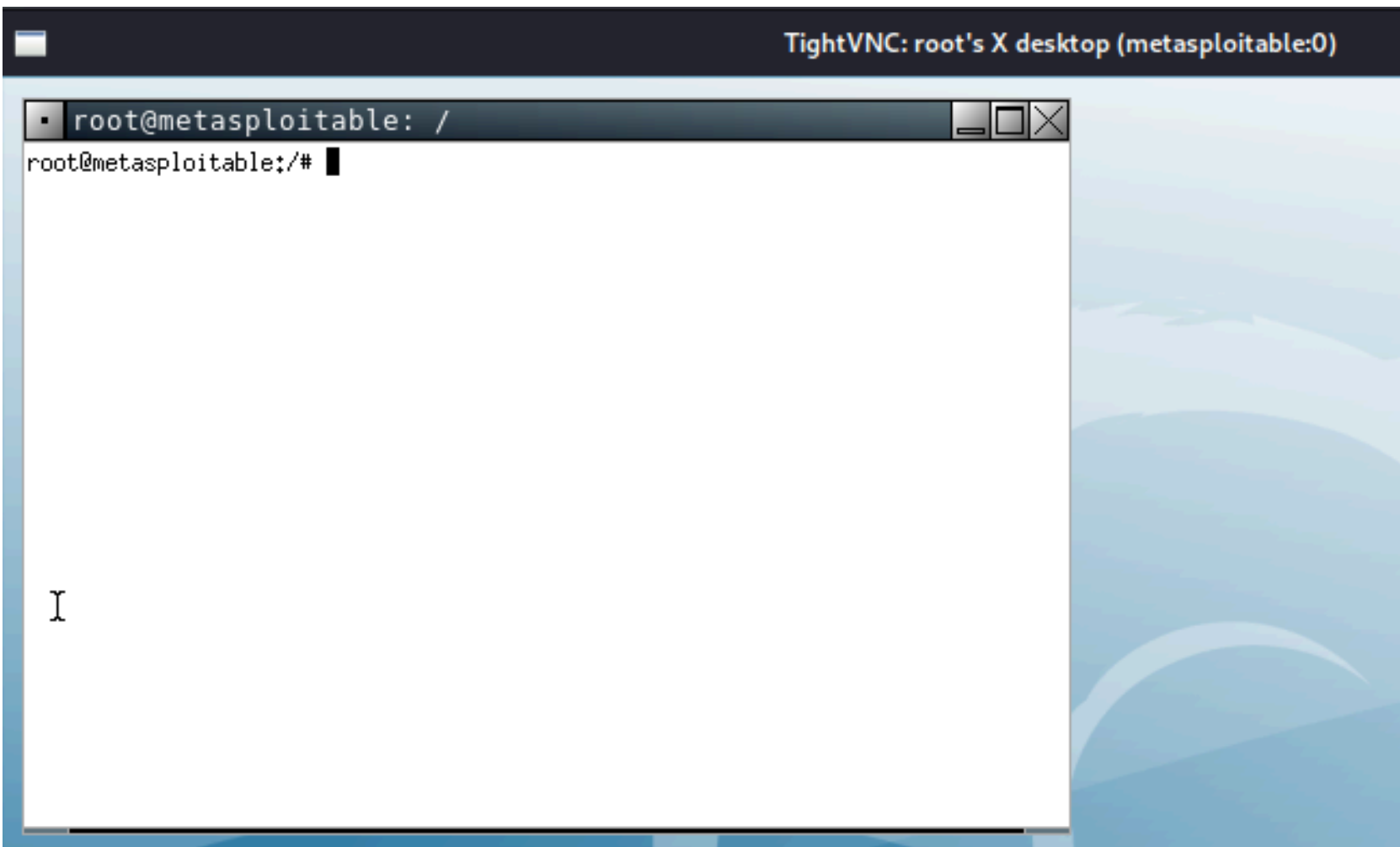
1. Executive Summary

Il presente documento riporta le azioni di rimedio eseguite su Metasploitable 2, un sistema Linux deliberatamente vulnerabile utilizzato come target in un ambiente di laboratorio controllato, la macchina attaccante è **Kali Linux (192.168.50.100)**, il target è **Metasploitable 2 (192.168.50.101)**. A seguito della scansione iniziale condotta con Nessus, sono state identificate 173 vulnerabilità totali, di cui 8 critiche con punteggio CVSS fino a 10.0, tra queste sono state selezionate 4 vulnerabilità critiche su cui intervenire con azioni di rimedio concrete, più una quinta mitigata tramite regola firewall come misura aggiuntiva. Le vulnerabilità affrontate comprendono: accesso remoto VNC con credenziale banale, una backdoor attiva che forniva shell root senza autenticazione sulla porta 1524, protocolli SSL obsoleti (v2/v3) esposti su porta 25 SMTP e 5432 PostgreSQL, e chiavi SSH generate con un generatore di numeri casuali difettoso (Debian RNG bug), la vulnerabilità SSL su porta 25 non è completamente rimediabile senza aggiornare OpenSSL 0.9.8 incluso in Ubuntu 8.04 EQL. In aggiunta, è stata applicata una regola iptables per bloccare il traffico sulla porta HTTP (80)

2. Implementazione delle Remediation

VNC Server “password” Password (Critical 10.0)

Il servizio **VNC (Virtual Network Computing)** consente l'accesso grafico remoto al desktop della macchina target, su Metasploitable 2, **il servizio era configurato con la password letterale 'password'** — una credenziale banale inclusa tra le prime voci di qualsiasi dizionario di attacco, chiunque si trovasse nella stessa rete poteva connettersi e ottenere un desktop grafico con privilegi di root senza alcun ostacolo



```
(kali@kali)-[~/Desktop]
$ nc -zv 192.168.50.101 5900
192.168.50.101: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.50.101] 5900 (?) open

(kali@kali)-[~/Desktop]
$ vncviewer 192.168.50.101
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

La password VNC è stata modificata tramite il comando **vncpasswd** direttamente sulla macchina Metasploitable, la nuova credenziale è robusta e non riconducibile a dizionari, successivamente, il processo VNC (Xtightvnc) è stato riavviato per applicare la modifica e la variazione è verificabile tramite la data di modifica del file `/home/msfadmin/.vnc/passwd`, aggiornata al momento dell'intervento

```
(kali@kali)-[~/Desktop]
$ vncviewer 192.168.50.101:1
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication failure

(kali@kali)-[~/Desktop]
$ vncviewer 192.168.50.101:1
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "msfadmin's X desktop (metasploitable:1)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

```
msfadmin@metasploitable:~$ ls -la ~/.vnc/passwd
-rw----- 1 msfadmin msfadmin 16 2026-06-27 07:05 /home/msfadmin/.vnc/passwd

msfadmin@metasploitable:~$ sudo kill -9 4646
msfadmin@metasploitable:~$ vncserver

Using password file /home/msfadmin/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
```

✓ **Risultato:** la connessione VNC con la vecchia password 'password' restituisce 'Authentication failure' in entrambi i display(:0;1), l'accesso è garantito esclusivamente con la nuova credenziale robusta

Bind Shell Backdoor Detection (Critical 9.8)

```
(kali@kali)-[~/Desktop]
$ nc 192.168.50.101 1524
root@metasploitable:/#
```

Sulla **porta 1524** era attiva una **backdoor** configurata tramite il demone inetd, la riga responsabile in /etc/inetd.conf era: **ingreslock stream tcp nowait root /bin/bash bash -i**, questa istruzione ordinava a inetd di aprire una shell bash interattiva come utente root per qualsiasi connessione in entrata sulla porta 1524, senza richiedere alcuna autenticazione, chiunque si connettesse con un semplice comando nc otteneva immediatamente accesso root completo alla macchina

```
msfadmin@metasploitable:~$ cat /etc/inetd.conf | grep -i "1524\|ingreslock"
ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$ sudo sed -i 's/ingreslock stream tcp nowait root/#ingreslock stream tcp nowait root/' /etc/inetd.conf
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ sudo /etc/init.d/openbsd-inetd restart
msfadmin@metasploitable:~$ grep ingreslock /etc/inetd.conf
#ingreslock stream tcp nowait root /bin/bash bash -i
```

La riga **ingreslock** è stata **commentata** in /etc/inetd.conf tramite sed, rimuovendola dalla configurazione attiva, poiché il processo xinetd gestiva comunque la porta 1524 indipendentemente da inetd, è **stato terminato forzatamente con kill -9 e disabilitato al boot impedendo il riavvio automatico**, la remediation è completa rilanciando il comando nc verificando che l'accesso non è più possibile

```
msfadmin@metasploitable:~$ sudo kill -9 4490
```

✓ **Risultato** :La connessione alla porta 1524 restituisce 'Connection refused', la backdoor è stata disabilitata commentando la entry in /etc/inetd.conf e terminando il processo xinetd

```
(kali@kali)-[~/Desktop]
$ nc 192.168.50.101 1524
(UNKNOWN) [192.168.50.101] 1524 (ingreslock) : Connection refused
```

SSL Version 2 and 3 Protocol Detection (Critical 9.8)

Il servizio **Postfix SMTP** sulla **porta 25** supportava **SSLv2** e **SSLv3**, due versioni del protocollo SSL considerate insicure e deprecate da oltre un decennio, **SSLv2 è vulnerabile ad attacchi DROWN** (Decrypting RSA with Obsolete and Weakened Encryption), **mentre SSLv3 è soggetto all'attacco POODLE** (Padding Oracle On Downgraded Legacy Encryption), entrambi consentono a un attaccante di intercettare e decifrare comunicazioni cifrate. **La verifica ha confermato un handshake SSLv3 riuscito con cipher DHE-RSA-AES256-SHA**, certificato scaduto dal 2010 e la firma MD5-SHA1, ne viene rifiutato il certificato dai browser dal 2017

```
No client certificate CA names sent
Peer signing digest: MD5-SHA1
Peer signature type: rsa_pkcs1_md5_sha1
Peer Temp Key: DH, 1024 bits
---
SSL handshake has read 1815 bytes and written 1891 bytes
Verification error: certificate has expired
---
New, SSLv3, Cipher is DHE-RSA-AES256-SHA
Protocol: TLSv1
Server public key is 1024 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
```

```
(kali@kali)-[~/Desktop]
$ openssl s_client -connect 192.168.50.101:25 -starttls smtp
Connecting to 192.168.50.101
CONNECTED(00000003)
```

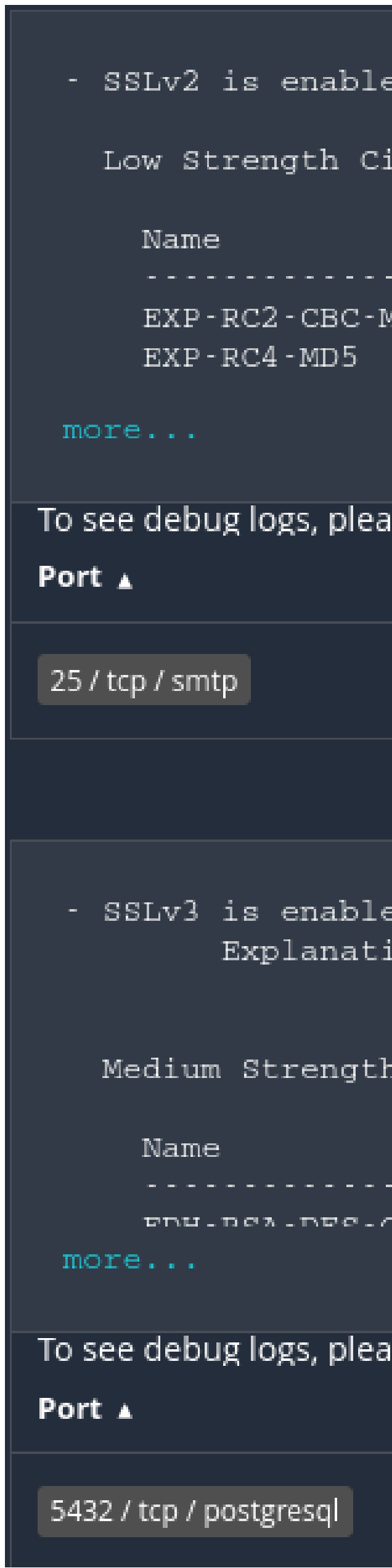
Sono state aggiunte due direttive al file di configurazione /etc/postfix/main.cf: smtpd_tls_protocols = !SSLv2, !SSLv3 (per le connessioni in entrata) e smtp_tls_protocols = !SSLv2, !SSLv3 (per quelle in uscita), il servizio Postfix è stato riavviato per applicare le modifiche. **Nella porta 5432 (PostgreSQL) è stato disabilitato SSL** tramite ssl=off in /etc/postgresql/8.3/main/postgresql.conf, invece per la porta 25 è stata tentata la disabilitazione tramite smtpd_tls_protocols e smtpd_use_tls=no in main.cf e MinProtocol in openssl.cnf, **a queste condizioni non è risolvibile perchè OpenSSL 0.9.8 su Ubuntu 8.04 EOL non supporta la restrizione per protocollo, si richiede un aggiornamento del sistema operativo**

```
mynetworks = 127.0.0.0/8 [::ffff:127.0.0.0]/104 [::1]/128
mailbox_size_limit = 0
recipient_delimiter = +
inet_interfaces = all
smtpd_tls_protocols = !SSLv2, !SSLv3
smtp_tls_protocols = !SSLv2, !SSLv3

[ Wrote 41 lines ]

msfadmin@metasploitable:~$ sudo /etc/init.d/postfix restart
* Stopping Postfix Mail Transport Agent postfix
* Starting Postfix Mail Transport Agent postfix
```

```
(kali@kali)-[~/Desktop]
$ openssl s_client -connect 192.168.50.101:25 -starttls smtp -no_tls1_3 -no_tls1_2 -no_tls1_1 -no_tls1
Connecting to 192.168.50.101
CONNECTED(00000003)
401729C6DD7F0000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:../ssl/statem/statem_lib.c:155:
no peer certificate available
No client certificate CA names sent
Negotiated TLS1.3 group: <NULL>
---
SSL handshake has read 234 bytes and written 40 bytes
Verification: OK
---
New, (NONE), Cipher is (NONE)
Protocol: TLSv1.3
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
```

Il Plugin Output di Nessus per la vulnerabilità SSL Version 2 and 3, con le porte rilevate: 25/tcp/smtp e 5432/tcp/postgresql , questo screen documenta quali porte erano effettivamente affette dalla vulnerabilità secondo Nessus, permettendo di concentrare le remediation sui target corretti invece di agire su porte non coinvolte

```
smtpd_tls_cert_file=/etc/ssl/certs/ssl-cert.pem
smtpd_tls_key_file=/etc/ssl/private/ssl-cert.pem
smtpd_use_tls=no
smtpd_tls_session_cache_timeout=0s
smtpd_tls_session_cache_database=stmp:/var/lib/pgsql/data/pgsql_tmpdir:/var/lib/pgsql/data/pgsql_tmpdir
```

La stringa smtpd_use_tls=no nel file /etc/postfix/main.cf , questa direttiva disabilita l'uso di TLS/SSL sul demone SMTP in entrata, è stata tentata come misura per eliminare SSLv2/v3 su Postfix, **ma non ha prodotto l'effetto desiderato a causa della versione di OpenSSL sottostante**

```
ssl = off
```

La stringa ssl = off nel file /etc/postgresql/8.3/main/postgresql.conf , questa direttiva disabilita completamente il supporto SSL in PostgreSQL, impedendo qualsiasi negoziazione di protocolli SSL/TLS inclusi SSLv2 e SSLv3

✓ **Risultato** :Vulnerabilità risolta in parte, la causa radice è la versione di OpenSSL (0.9.8) integrata in Ubuntu 8.04, che non permette di escludere singoli protocolli SSL senza un aggiornamento del sistema operativo

Debian OpenSSH/OpenSSL RNG Weakness (Critical 10.0)

Nel 2008 fu scoperto un **grave bug nel generatore di numeri casuali (RNG) presente nelle versioni Debian e Ubuntu di OpenSSL**, a causa di una modifica errata al codice, il pool di entropia usato per generare chiavi crittografiche era ridotto a soli 32.768 valori possibili — **rendendo le chiavi SSH generate con questo RNG completamente prevedibili e riproducibili**, le chiavi SSH host di Metasploitable 2 erano state generate con questa versione vulnerabile, esponendo il server a potenziali attacchi man-in-the-middle e alla compromissione della sessione cifrata

```
msfadmin@metasploitable:~$ sudo dpkg-reconfigure openssh-server
* Restarting OpenBSD Secure Shell server sshd [ OK ]
msfadmin@metasploitable:~$ ssh-keygen -l -f /etc/ssh/ssh_host_rsa_key.pub
2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 /etc/ssh/ssh_host_rsa_key.pub
```

```
(kali@kali)-[~/Desktop]
$ ssh -oHostKeyAlgorithms=+ssh-rsa msfadmin@192.168.50.101
The authenticity of host '192.168.50.101 (192.168.50.101)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GCI0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.50.101' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Connection closed by 192.168.50.101 port 22
```

Le chiavi SSH host sono state rigenerate tramite il comando sudo dpkg-reconfigure openssh-server, che rimuove le chiavi esistenti e ne genera di nuove utilizzando il generatore di entropia corretto del sistema, il nuovo fingerprint RSA differisce da quello precedente (SHA256:YpsmzyIMK21P66i16uGj3pVay+/3ZZOtFMPC kRfCr1w), confermando la sostituzione

✓ **Risultato**: le nuove chiavi SSH sono generate con RNG corretto, il fingerprint del server è cambiato, rendendo inutilizzabili eventuali chiavi precedentemente compromesse

Regola Firewall — iptables (porta 80) (Misura Aggiuntiva)

Come misura aggiuntiva, è stata applicata una regola firewall tramite iptables per bloccare il traffico in entrata sulla porta 80 (HTTP), la porta era aperta e raggiungibile da Kali, esponendo il servizio HTTP di Metasploitable a potenziali attacchi. L'utilizzo di iptables rappresenta un approccio di difesa perimetrale: anche quando un servizio non può essere immediatamente aggiornato o disabilitato, una regola firewall può limitarne l'esposizione

```
(kali㉿kali)-[~/Desktop]
$ nc -zv 192.168.50.101 80
192.168.50.101: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.50.101] 80 (http) open
```

```
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 80 -j DROP
[sudo] password for msfadmin:
msfadmin@metasploitable:~$
```

```
(kali㉿kali)-[~/Desktop]
$ nc -zv 192.168.50.101 80
192.168.50.101: inverse host lookup failed: Host name lookup failure
^C

(kali㉿kali)-[~/Desktop]
$ nc -zv -w 3 192.168.50.101 80
192.168.50.101: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.50.101] 80 (http) : Connection timed out
```

Sul sistema Metasploitable è stato eseguito il comando: **sudo iptables -A INPUT -p tcp --dport 80 -j DROP**, questa regola aggiunge alla catena INPUT una politica di DROP per tutto il traffico TCP diretto alla porta 80, rendendo il servizio irraggiungibile dall'esterno senza interromperne il processo interno, come si vede da Kali

✓ **Risultato:** la connessione alla porta 80 da Kali va in timeout ('Connection timed out'), i pacchetti vengono droppati dalla regola iptables prima di raggiungere il servizio, confermando l'efficacia della misura